Procédure Gestion des vulnérabilités et des correctifs de sécurité

Domaine :	Sécurité des systèmes d'information
Macro Processus :	Opérations de sécurité
Processus :	Gestion des vulnérabilités
Référence :	SEC-04
Version :	1.5

Responsables du document

	Nom	Entité	Date
Rédacteur(s)	Ayoub Zerhouni (Consultant Organisation)	DTPO	27/02/2026
Vérificateur(s)	Reda Cherkaoui (Responsable des Opérations de Sécurité)	DSSI	19/03/2026
	Ilham Tazi (Responsable de la Sécurité des Systèmes d'Information (RSSI))	DSSI	19/03/2026
	Nadia Berrada (Responsable Infrastructures et Cloud)	DSI	19/03/2026
	Youssef Amrani (Responsable Études et Développement)	DSI	19/03/2026
Approbateur(s)	Ilham Tazi (Responsable de la Sécurité des Systèmes d'Information (RSSI))	DSSI	03/04/2026
	Karim Benjelloun (Directeur des Systèmes d'Information)	DSI	03/04/2026
	Najat Belkadi (Directrice Transformation, Processus et Organisation)	DTPO	03/04/2026

Propriétaire de la procédure : Reda Cherkaoui (Responsable des Opérations de Sécurité).

Historique des révisions

Emetteur	Description	Demande de révision	Version	Approbation
Ayoub Zerhouni	Création de la procédure		1.0	07/03/2023
Ayoub Zerhouni	Délais de correction alignés sur le projet PRJ-SOC-2025	DR-2026-21	1.5	13/04/2026

Généralités

Objet

Cette procédure décrit l'identification, l'évaluation et la correction des vulnérabilités sur le parc informatique d'Orizia. Elle fixe les délais de correction selon la gravité.

Domaine d'application

Entrent dans le périmètre

- Serveurs, postes de travail, équipements réseau et applications
- Vulnérabilités détectées par OriVuln ou signalées par des sources externes

Sont exclus du périmètre

- Vulnérabilités des applications éditeurs hors périmètre de support

Références

- Politique de sécurité des systèmes d'information d'Orizia
- Échelle de criticité CVSS
- Procédure aval IT-02 – Gestion des changements informatiques : Les correctifs sont déployés par des changements.
- Procédure aval IT-05 – Gestion des mises en production applicatives : Les vulnérabilités critiques bloquent les mises en production applicatives.
- Procédure complémentaire SEC-03 – Gestion des incidents de sécurité : Une vulnérabilité exploitée donne lieu à un incident de sécurité.
- Projet : PRJ-SOC-2025 – Mise en place du centre des opérations de sécurité (OriSOC).

Définitions

- OriVuln : Scanner de vulnérabilités.
- OriCMDB : Référentiel des actifs et des éléments de configuration informatiques.
- OriDesk : Outil de gestion des services informatiques (incidents, demandes, changements).
- RSSI : Responsable de la Sécurité des Systèmes d'Information.

Acteurs

Acteur	Direction / Entité	Rôle dans la procédure
Responsable des Opérations de Sécurité	DSSI	Pilote les scans et la priorisation
Propriétaire de l'actif	DSI	Planifie et applique la correction
Responsable Infrastructures et Cloud	DSI	Déploie les correctifs d'infrastructure
Responsable Études et Développement	DSI	Corrige les vulnérabilités applicatives
Responsable de la Sécurité des Systèmes d'Information	DSSI	Accorde les dérogations

Sommaire

Responsables du document
Historique des révisions
Généralités
Objet
Domaine d'application
Références
Définitions
Acteurs
Règles de gestion
Liste des contrôles
Logigramme
Commentaires du logigramme
Opérations
Annexes

Règles de gestion

I- Pré-requis

La réalisation de la procédure nécessite la disponibilité des éléments suivants :

- Actifs référencés dans OriCMDB
- OriVuln configuré pour le périmètre

II- Règles applicables

R1. Une vulnérabilité critique est corrigée sous 7 jours calendaires.

R2. Une vulnérabilité élevée est corrigée sous 30 jours calendaires.

R3. Une vulnérabilité moyenne est corrigée sous 90 jours calendaires.

R4. Une vulnérabilité critique non corrigée dans le délai fait l'objet d'une dérogation écrite du RSSI et de mesures compensatoires.

R5. Un scan complet de l'ensemble du parc est réalisé chaque mois.

R6. Une vulnérabilité critique non corrigée empêche la mise en production de l'application concernée (IT-05).

R7. Les correctifs sont déployés par des changements approuvés selon la procédure IT-02.

III- Exceptions et cas particuliers

- Un correctif d'urgence répondant à une exploitation active est déployé en changement urgent selon IT-02.
- Lorsque le correctif risque de perturber un service critique, une dérogation est accordée par le RSSI avec isolement de l'actif.

IV- Sorties et archivage

- Sortie : Rapport de scan
- Sortie : Tableau de bord des vulnérabilités
- Les rapports de scan sont conservés 3 ans.

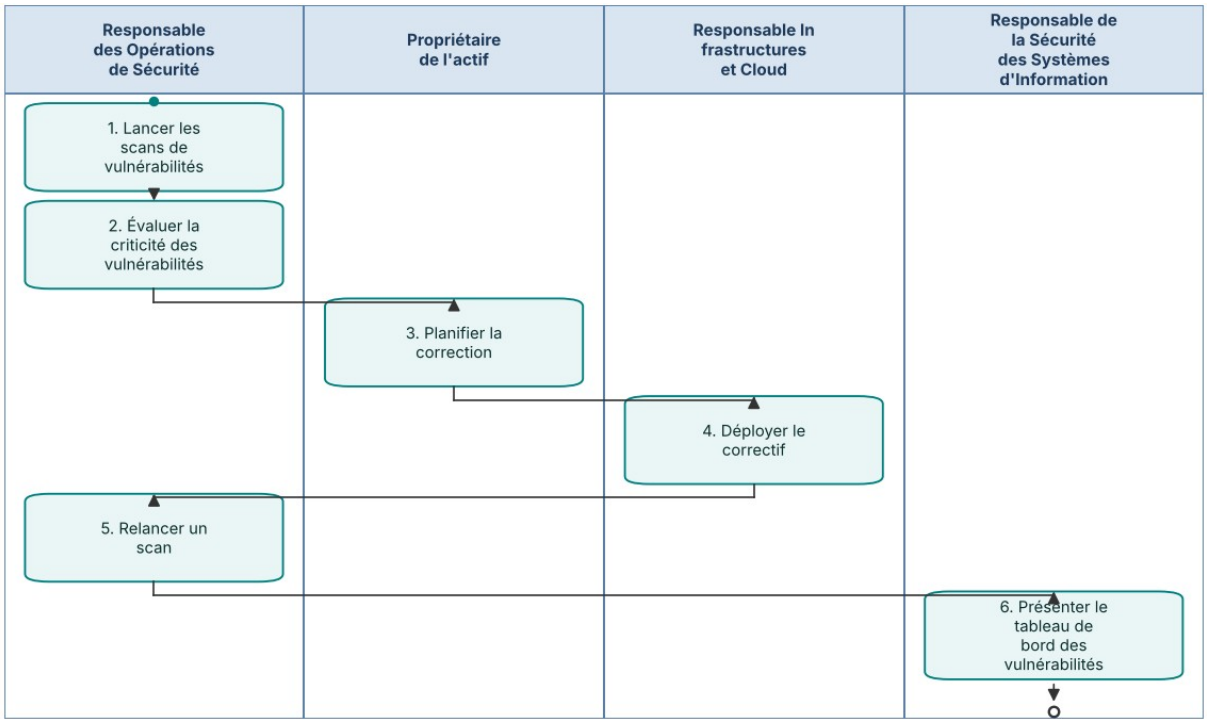
V- Indicateurs de suivi

Indicateur	Cible
Taux de vulnérabilités critiques corrigées dans le délai	95 % minimum
Taux de couverture des scans	98 % du parc
Nombre de dérogations ouvertes	5 maximum

Liste des contrôles

N°	Contrôle	Responsable du contrôle	Fréquence
C1	Suivi hebdomadaire des vulnérabilités critiques ouvertes	Responsable des Opérations de Sécurité	Hebdomadaire
C2	Contrôle des dérogations et de leurs mesures compensatoires	Responsable de la Sécurité des Systèmes d'Information	Trimestrielle
C3	Audit de couverture des scans par rapport à OriCMDB	Contrôle Permanent	Annuelle

Logigramme



Commentaires du logigramme

Opérations

Temporisateur : Hebdomadaire

Libellé de l'opération	Acteur
1. Lancer les scans de vulnérabilités	**Responsable des Opérations de Sécurité**
Commentaires : Lance les scans de vulnérabilités sur le périmètre planifié. *Outil(s) : OriVuln. Délai : Hebdomadaire.*	

Libellé de l'opération	Acteur
2. Évaluer la criticité des vulnérabilités	**Responsable des Opérations de Sécurité**
Commentaires : Évalue la criticité des vulnérabilités et ouvre un ticket par actif concerné. *Outil(s) : OriVuln, OriDesk. Délai : 2 jours ouvrés.*	

Libellé de l'opération	Acteur
3. Planifier la correction	**Propriétaire de l'actif**
Commentaires : Planifie la correction et dépose la demande de changement selon IT-02. *Outil(s) : OriDesk. Délai : Selon criticité.*	

Libellé de l'opération	Acteur
4. Déployer le correctif	**Responsable Infrastructures et Cloud**
Commentaires : Déploie le correctif dans la fenêtre autorisée. *Outil(s) : OriDesk. Délai : Selon criticité.*	

Libellé de l'opération	Acteur
5. Relancer un scan	**Responsable des Opérations de Sécurité**
Commentaires : Relance un scan pour vérifier la correction et clôture le ticket. *Outil(s) : OriVuln. Délai : 5 jours ouvrés.*	

Libellé de l'opération	Acteur
6. Présenter le tableau de bord des vulnérabilités	**Responsable de la Sécurité des Systèmes d'Information**
Commentaires : Présente le tableau de bord des vulnérabilités au Comité de Sécurité des Systèmes d'Information. *Outil(s) : OriVuln. Délai : Mensuelle.*	

Annexes

Sans objet.